

**ФЕДЕРАЛЬНОЕ ГОСУДАРСТВЕННОЕ АВТОНОМНОЕ ОБРАЗОВАТЕЛЬНОЕ УЧРЕЖДЕНИЕ ВЫСШЕГО
ОБРАЗОВАНИЯ
«САНКТ-ПЕТЕРБУРГСКИЙ НАЦИОНАЛЬНЫЙ ИССЛЕДОВАТЕЛЬСКИЙ
УНИВЕРСИТЕТ ИНФОРМАЦИОННЫХ ТЕХНОЛОГИЙ,
МЕХАНИКИ И ОПТИКИ»**

Факультет безопасности информационных технологий

Дисциплина:

«Теория информационной безопасности и методология защиты информации»

ОТЧЕТ ПО ЛАБОРАТОРНОЙ РАБОТЕ №5

Модели безопасности

Выполнил:

Студент гр. N3248

Жук Анастасия Валерьевна

Проверил:

Кондратенко Станислав Сергеевич

Санкт-Петербург

2024 г.

Цель работы: изучить существующие модели безопасности и примеры их реализации

Ход работы:

1. выбрать с преподавателем одну из рассмотренных на лекции моделей (<https://drive.google.com/file/d/1UIkT1IGN52f2wtk4IdUmyZGQDVPxmdDE/view?usp=sharing>) (также представлены ниже в документе)
2. тщательно изучить выбранную модель
3. придумать пример в реальной организации/ информационной системе с использованием выбранной модели
4. составить презентацию (до 10 слайдов) с описанием и примером записать короткое видео (до 3 минут) по презентации, объясняющее особенности модели и ее применения, и выложить на гугл-диск вместе с презентацией

Модели для изучения:

1. По принципу предоставления прав (контроля конфиденциальности):
 1. дискреционные (Адепт, Харрисона-Руззо-Ульмана, пространство Хартсона)
 2. мандатные (Белла-Лападула, Z)
 3. MMS
 4. модели невмешательства и невыводимости
 5. игровая модель и модель с полным перекрытием (+Клеменса)
2. Контроля целостности:
 1. Модель Биба с вариациями
 2. Кларка-Вилсона
3. Распределения ресурсов (контроль отказа в обслуживании):
 1. Мандатная модель ОВО
 2. Модель Миллена

Ход работы

Модель безопасности

Модель безопасности – это совокупность норм и правил, регламентирующих процесс обработки информации, выполнение которых обеспечивает защиту от определенного множества угроз и составляет необходимое условие безопасности системы. [1] Целью модели является формулировка требований к безопасности, которой должна обладать рассматриваемая система. [2] Модель безопасности анализирует свойства системы и определяет те потоки информации, которые в ней разрешены.

При рассмотрении модели безопасности используются такие понятия как доступ к информации, правила разграничения доступа, объект и субъект доступа. [2] Дадим точные определения каждого из них.

Доступ к информации подразумевает ознакомление с информацией и проведение над информацией таких операций как обработка, копирование, модификация и уничтожение информации. [2]

Правила разграничения доступа — набор правил, регламентирующих права доступа субъектов к объектам доступа. [2]

Объект доступа — единица информационного ресурса автоматизированной системы, доступ к которой регламентируется правилами разграничения доступа. [2]

Субъект доступа — это лицо или процесс, действия которого регламентируются правилами разграничения доступа. [2]

Сами модели безопасности различают по используемой в ней политики безопасности. [2] Политика безопасности может зависеть от конкретной технологии обработки информации, используемых технических и программных средств и от расположения организации, в которой описана данная политика безопасности.

Пятимерное пространство Хартсона

В данной модели используется пятимерное пространство безопасности для моделирования процессов, установления полномочий и организации доступа на их основании. Модель имеет пять основных наборов:

- Установленные полномочия (A);
- Пользователи (U);
- Операции (E);
- Ресурсы (R);
- Состояния (S).

Таким образом, область безопасности в данной модели будет представлять собой декартово произведение данных наборов [2]. В данном случае, в качестве доступа будут считаться запросы, введенные пользователями для выполнения каких-либо операций над ресурсами системы.

Пользователи запрашивают доступ к ресурсам. Если у них это удастся, система переходит в новое для неё состояние. Запрос в данном случае выглядит как четырёхмерный кортеж вида $q = (u, e, R', s)$, где $u \in U$, $e \in E$, $s \in S$, $R' \subseteq R$ (R' -требуемый набор ресурсов).

После формирования кортежа происходит выполнение следующего алгоритма [3]:

1. Вызвать все вспомогательные программы, необходимые для предварительного принятия решений.
2. Определить из U те группы пользователей, к которым принадлежит u . Затем выбрать из P спецификации полномочий, которым соответствуют выделенные группы пользователей. Этот набор полномочий $F(u)$ определяет привилегию пользователя u .
3. Определить из P набор $F(e)$ полномочий, которые устанавливают e как основную операцию. Этот набор называется привилегией операции e .
4. Определить из P набор $F(R)$ (привилегию единичного ресурса R) – полномочия, которые определяют поднабор ресурсов из R' , имеющего общие элементы с запрашиваемой единицей ресурса R .

Полномочия, которые являются общими для трех привилегий в процедурах 2, 3, 4, образуют $D(q)$ (так называемый домен полномочий для запроса): $q: D(q) = F(u) \cap F(e) \cap F(R)$.

5. Удостовериться, что запрашиваемый ресурс R полностью включается в $D(q)$, то есть каждый элемент из R должен содержаться в некоторой единице ресурса, которая определена в домене полномочий $D(q)$.
6. Осуществить разбиение набора $D(q)$ на эквивалентные классы так, чтобы два полномочия попадали в эквивалентный класс тогда и только тогда,

когда они специфицируют одну единицу ресурса. Для каждого такого класса логическая операция ИЛИ (или И) выполняется с условиями доступа элементов каждого класса. Новый набор полномочий – один на каждую единицу ресурса, указанную в $D(q)$, есть $F(u, q)$ – фактическая привилегия пользователя u по отношению к запросу q .

7. Вычислить ЕАС - условие фактического доступа, соответствующего запросу q , осуществляя логическое И (или ИЛИ) над условиями доступа членов $F(u, q)$. Это И (или ИЛИ) выполняется над всеми единицами ресурсов, которые перекрывают единицу запрошенного ресурса.
8. Оценить ЕАС и принять решение о доступе:
 - разрешить доступ к R , если R перекрывается;
 - отказать в доступе в противном случае.
9. Произвести запись необходимых событий.
10. Вызвать все программы, необходимые для организации доступа после "принятия решения".
11. Выполнить все вспомогательные программы, вытекающие для каждого случая из условия 8.
12. Если решение о доступе было положительным – завершить физическую обработку. Однако по мнению самого автора модели Хартстона данный алгоритм не всегда требуется осуществлять в полном объеме. Другими словами, некоторые из этих шагов можно опустить при решении задачи доступа к ресурсам.

Следует отметить, что в связи с трудоёмким алгоритмом модель безопасности Хартстона не получила широкого практического применения.

Плюсы применения данной модели на практике:

- *Многоуровневая структура*: пятимерное пространство позволяет моделировать безопасность на разных уровнях и с разных точек зрения, что помогает глубже понять угрозы и риски.
- *Гибкость*: модель может быть адаптирована под различные условия и ситуации, что позволяет использовать ее в разных областях.
- *Комплексный подход*: включает в себя различные аспекты безопасности, что помогает обеспечить более комплексное решение.

Минусы применения данной модели на практике:

- *Сложность восприятия*: пятимерное пространство может быть сложным для понимания и анализа.

- *Проблемы с реализацией:* на практике трудно реализовать концептуальные модели, и они могут не всегда давать четкие указания на действия, которые следует предпринять.
- *Необходимость в ресурсах:* разработка и поддержка содержания модели может требовать значительных временных и материальных ресурсов, что не всегда возможно.
- *Неоднозначность:* некоторые аспекты модели могут быть интерпретированы по-разному, что может привести к путанице или неправильным выводам.

Пример:

В организации Ростелеком решили улучшить данных, обеспечив высокий уровень контроля над доступом к информации. Для этого было решено использовать модель доступа «Пятимерное пространство Хартсона».

Почему могла возникнуть идея в использовании именно этой модели?

Дело в том, что данная модель позволяет задать более точные правила доступа к файлам, учитывая группу, в которую входит пользователь, установленные полномочия для доступа к ресурсу, тип ресурса, разрешенные действия над этим ресурсом и необходимое состояние системы.

Список используемых источников

1. Политика и модели безопасности. URL: <https://clck.ru/3EsBzT> (дата обращения: 27.11.2024).
2. Жилин, В. В. Модели безопасности на основе дискреционной политики / В. В. Жилин, И. И. Дроздова. — Текст : непосредственный // Технические науки в России и за рубежом : материалы VII Междунар. науч. конф. (г. Москва, ноябрь 2017 г.). — Москва : Буки-Веди, 2017. — С. 21-23. — URL: <https://moluch.ru/conf/tech/archive/286/13234/> (дата обращения: 27.11.2024).
3. Коржук В. М. Лекция 5-6. Модели безопасности URL: <https://drive.google.com/file/d/1UIkT1IGN52f2wtk4IdUmyZGQDVpxmdDE/view> (дата обращения: 27.11.2024)